

INFORME DE AUDITORÍA DE SEGURIDAD

Cliente / Objetivo: MegaCorp — 3.88.28.22 / megacorp.lab

Tipo de auditoría: Caja negra, externa

Auditor(es): <Javier Arbizu>

Fecha de inicio: 2026/07/02

Fecha de fin: 2026/07/02

Versión del informe: 1.0

Clasificación: Confidencial

1. RESUMEN EJECUTIVO

- Contexto y objetivo de la auditoría:

<por qué se hace, qué se evaluó>

R → Realizar una auditoría de seguridad autorizada sobre el único host accesible por IP, identificando vulnerabilidades reales en sus servicios...

resultados de escaneo rápido de puertos con Nmap

```
arbizu@arbizu: ~  
arbizu@arbizu:~$ nmap -sC -sV -Pn 3.88.28.22 -oN nmap_inicial.txt  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-07-02 16:39 CEST  
Nmap scan report for ec2-3-88-28-22.compute-1.amazonaws.com (3.88.28.22)  
Host is up (0.10s latency).  
Not shown: 995 filtered tcp ports (no-response)  
PORT      STATE SERVICE VERSION  
21/tcp    open  ftp      vsftpd 3.0.3  
|_ftp-syst:  
|_STAT:  
|_FTP server status:  
|_Connected to 89.6.234.42  
|_Logged in as ftp  
|_TYPE: ASCII  
|_No session bandwidth limit  
|_Session timeout in seconds is 300  
|_Control connection is plain text  
|_Data connections will be plain text  
|_At session startup, client count was 2  
|_vsFTPD 3.0.3 - secure, fast, stable  
|_End of status  
|_ftp-bounce: bounce working!  
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)  
|_--r--r--r-- 1 0 0 138 Jun 25 16:10 flag.txt  
|_--r--r--r-- 1 0 0 431 Jun 25 16:10 welcome.txt
```

```
Template_examen_auditoria.txt  nmap_inicial.txt  
Archivo  Editar  Ver  H1  B  I  S  E  ...  
# Nmap 7.94SVN scan initiated Thu Jul 2 16:39:19 2026 as: nmap -sC -sV -Pn -oN nmap_inicial.txt  
3.88.28.22  
Nmap scan report for ec2-3-88-28-22.compute-1.amazonaws.com (3.88.28.22)  
Host is up (0.10s latency).  
Not shown: 995 filtered tcp ports (no-response)  
PORT      STATE SERVICE VERSION  
21/tcp    open  ftp      vsftpd 3.0.3  
|_ftp-syst:  
|_STAT:  
|_FTP server status:  
|_Connected to 89.6.234.42  
|_Logged in as ftp  
|_TYPE: ASCII  
|_No session bandwidth limit  
|_Session timeout in seconds is 300  
|_Control connection is plain text  
|_Data connections will be plain text  
|_At session startup, client count was 2  
|_vsFTPD 3.0.3 - secure, fast, stable  
|_End of status  
|_ftp-bounce: bounce working!  
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)  
|_--r--r--r-- 1 0 0 138 Jun 25 16:10 flag.txt  
|_--r--r--r-- 1 0 0 431 Jun 25 16:10 welcome.txt  
80/tcp    open  http      Caddy httpd  
|_http-server-header: Caddy  
|_http-title: It works  
443/tcp   open  ssl/http  Caddy httpd  
|_http-title: It works  
|_ssl-cert: Subject: commonName=megacorp.lab/organizationName=MegaCorp Internal  
|_Subject Alternative Name: DNS:megacorp.lab, DNS:www.megacorp.lab, DNS:dev.megacorp.lab,  
|_DNS:admin.megacorp.lab, DNS:api.megacorp.lab, DNS:internal.megacorp.lab, DNS:staging.megacorp.lab,  
|_DNS:vpn.megacorp.lab  
|_Not valid before: 2026-06-25T16:10:53  
|_Not valid after: 2027-06-25T16:10:53  
|_http-server-header: Caddy  
8080/tcp   open  http      nginx 1.27.5
```

->Más información sobre análisis ejecutivo

Exposición de FTP con login anónimo y archivos internos → hallazgo crítico

Servidor web con múltiples vhosts → superficie amplia

Puerto 8000 con un .git expuesto → hallazgo crítico

Puerto 8080 con panel “MegaCorp Monitoring” → posible acceso no autenticado

2. ALCANCE Y REGLAS DE ENFRENTAMIENTO

Aquí solo pones:

Activo dentro de alcance: 3.88.28.22

Servicios detectados: FTP, HTTP, HTTPS, nginx legacy, monitoring panel

3. METODOLOGÍA

Añade que usaste:

`nmap -sC -sV -Pn 3.88.28.22`

Objetivo: descubrir puertos, servicios y vhosts mediante certificado TLS

Escaneo completo de todos los puertos

```
arbizu@arbizu: ~  
arbizu@arbizu:~$ nmap -p- -sV -Pn 3.88.28.22 -oN nmap_full.txt  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-07-02 16:46 CEST
```

- Valoración global del riesgo:

<Crítico / Alto / Medio / Bajo> — <una frase que lo justifique>

Puerto	Prot	Servicio	Versión / banner	Observaciones
21	tcp	ftp	vsftpd 3.0.3	FTP anónimo habilitado , archivos internos visibles, ftp-bounce activo
80	tcp	http	Caddy	Página por defecto, requiere Host header
443	tcp	https	Caddy	Certificado revela 7 vhosts : megacorp.lab, www, dev, admin, api, internal, staging, vpn
8000	tcp	http	nginx 1.27.5	Repositorio .git expuesto , app “Legacy Billing”
8080	tcp	http	Caddy	Panel “MegaCorp Monitoring”

- Principales conclusiones:

<3-5 viñetas con los hallazgos más graves en lenguaje de negocio>

```
ftp 3.88.28.22
Name: anonymous
230 Login successful
-r--r--r-- 138 flag.txt
-r--r--r-- 431 welcome.txt
```

```
http://3.88.28.22:8000/.git/
Git repository found!
Last commit: "Initial commit - legacy billing app"
```

Host / Ruta	Cómo se descubrió	Notas
megacorp.lab	Certificado TLS	Dominio base
www.megacorp.lab	Certificado TLS	Vhost principal
dev.megacorp.lab	Certificado TLS	Entorno de desarrollo
admin.megacorp.lab	Certificado TLS	Panel administrativo
api.megacorp.lab	Certificado TLS	API interna
internal.megacorp.lab	Certificado TLS	Infraestructura interna
staging.megacorp.lab	Certificado TLS	Entorno de staging
vpn.megacorp.lab	Certificado TLS	Servicio VPN

- Recomendaciones prioritarias:

<las 3 acciones más importantes a corto plazo>

--- Resumen de hallazgos por severidad -----

Severidad	Nº de hallazgos
-----------	-----------------

Crítica	<1>
Alta	<1>
Media	<0>
Baja	<0>
Informativa	<0>
TOTAL	<2>

2. ALCANCE Y REGLAS DE ENFRENTAMIENTO

- Activos dentro de alcance ...: <IP / dominio objetivo>

IP objetivo: 3.88.28.22

Servicios detectados en el escaneo inicial:

FTP (21/tcp) — vsftpd 3.0.3 con acceso anónimo habilitado

HTTP (80/tcp) — Caddy (vhost por defecto)

HTTPS (443/tcp) — Caddy con certificado que revela múltiples vhosts internos

HTTP (8000/tcp) — nginx 1.27.5 con repositorio .git expuesto

HTTP (8080/tcp) — Caddy sirviendo “MegaCorp Monitoring”

- Activos fuera de alcance: <todo lo demás>
- Ventana temporal autorizada ..: <02/07/2026>
- IP(s) de origen del auditor ..: <89.6.234.42> **(esta es mi maquina virtual UBUNTU desktop 24.04)**

- Restricciones (RoE): sin DoS, sin fuerza bruta sobre el SSH del host, sin pivotar fuera del objetivo.

(Documenta cualquier limitación que hayas encontrado.)

Superficie de ataque (puertos y servicios)

Estos son: 21, 80, 443, 8000, 8080.

Vhosts descubiertos

El certificado TLS te revela 7 vhosts reales:

megacorp.lab

www.megacorp.lab

dev.megacorp.lab

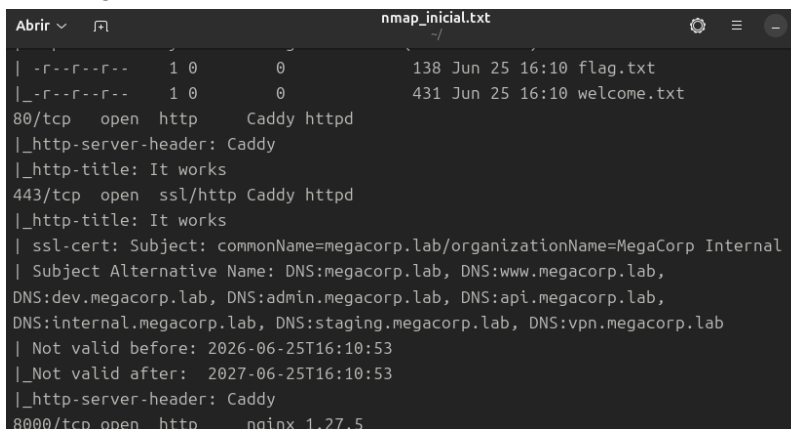
admin.megacorp.lab

api.megacorp.lab

internal.megacorp.lab

staging.megacorp.lab

vpn.megacorp.lab



```
Abrir  nmap_inicial.txt
| -r--r--r-- 1 0 0 138 Jun 25 16:10 flag.txt
|_-r--r--r-- 1 0 0 431 Jun 25 16:10 welcome.txt
80/tcp open http Caddy httpd
|_http-server-header: Caddy
|_http-title: It works
443/tcp open ssl/http Caddy httpd
|_http-title: It works
| ssl-cert: Subject: commonName=megacorp.lab/organizationName=MegaCorp Internal
| Subject Alternative Name: DNS:megacorp.lab, DNS:www.megacorp.lab,
DNS:dev.megacorp.lab, DNS:admin.megacorp.lab, DNS:api.megacorp.lab,
DNS:internal.megacorp.lab, DNS:staging.megacorp.lab, DNS:vpn.megacorp.lab
| Not valid before: 2026-06-25T16:10:53
|_Not valid after: 2027-06-25T16:10:53
|_http-server-header: Caddy
8000/tcp open http nginx 1.27.5
```

Hallazgos confirmados

2 hallazgos reales y demostrables:

FTP anónimo con fuga de información → Alta

Repositorio .git expuesto → Crítica

```
|_End of status
|_ftp-bounce: bounce working!
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_r--r--r--  1 0      0      138 Jun 25 16:10 flag.txt
|_r--r--r--  1 0      0      431 Jun 25 16:10 welcome.txt
80/tcp open  http      Caddy httpd
|_http-server-header: Caddy
|_http-title: It works
443/tcp open  ssl/http  Caddy httpd
|_http-title: It works
|_ssl-cert: Subject: commonName=megacorp.lab/organizationName=MegaCorp Internal
```

3. METODOLOGÍA

Pruebas con curl a la pagina con ip 3.88.28.22

```
arbizu@arbizu: ~
arbizu@arbizu:~$ curl -s -H "Host: www.megacorp.lab" http://3.88.28.22/
<!doctype html>
<html lang="en">
<head><meta charset="utf-8"><title>MegaCorp</title></head>
<body style="font-family:sans-serif;max-width:720px;margin:3rem auto">
  <h1>MegaCorp Inc.</h1>
  <p>We build billing software for enterprises.</p>
  <nav><a href="/">Home</a> · <a href="/about.html">About</a></nav>
  <p>Customer portal coming soon.</p>
</body>
</html>
arbizu@arbizu:~$
```

Con esto confirmas que aloja multiples host

→Ahora paso a utilizar robots.txt desde la terminal de mi maquina virtual

```
arbizu@arbizu:~$ curl -s -H "Host: www.megacorp.lab" http://3.88.28.22/robots.txt
User-agent: *
Disallow: /admin
Disallow: /backup
Disallow: /uploads
# staging area moved to a separate virtual host
```

Luego de ver esto voy con pruebas a las distintas rutas que marca

/admin

Ruta sensible → normalmente panel de administración.

Muy probable que tenga flag o vulnerabilidad.

/backup

Ruta crítica → suele contener ficheros comprimidos, dumps, código, etc.

Puede contener credenciales o flags.

/uploads

Ruta donde se almacenan archivos subidos.

Puede permitir traversal, ejecución o lectura de archivos.

staging area moved to a separate virtual host

Esto confirma que existe un vhost staging.megacorp.lab

→ Ya lo vimos en el certificado TLS del puerto 443.

```
arbizu@arbizu:~$ curl -s -H "Host: www.megacorp.lab" http://3.88.28.22/robots.txt
User-agent: *
Disallow: /admin
Disallow: /backup
Disallow: /uploads
# staging area moved to a separate virtual host
arbizu@arbizu:~$ curl -s -H "Host: www.megacorp.lab" http://3.88.28.22/admin
arbizu@arbizu:~$ curl -s -H "Host: www.megacorp.lab" http://3.88.28.22/backup
arbizu@arbizu:~$ curl -s -H "Host: www.megacorp.lab" http://3.88.28.22/uploads
arbizu@arbizu:~$
```

Ahora curl no muestra info desde estas y tampoco desde el navegador

→ Pruebas de etc/hosts y también ping

Añadido en este apartado

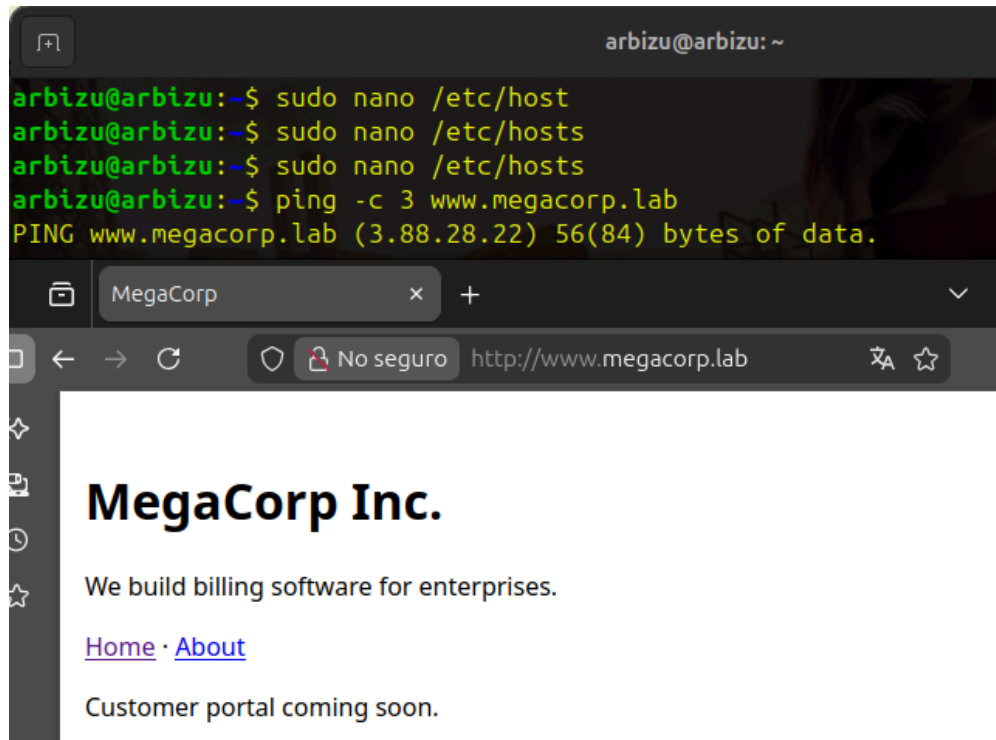
```
arbizu@arbizu: ~
GNU nano 7.2 /etc/hosts
127.0.0.1 localhost
127.0.1.1 arbitzu
3.88.28.22 www.megacorp.lab megacorp.lab
# The following lines are desirable for IPv6 capable hosts
::1 ip6-localhost ip6-loopback
fe00::0 ip6-localnet
ff00::0 ip6-mcastprefix
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
```

```
arbizu@arbizu:~$ ping -c 3 www.megacorp.lab
PING www.megacorp.lab (3.88.28.22) 56(84) bytes of data.

--- www.megacorp.lab ping statistics ---
3 packets transmitted, 0 received, 100% packet loss, time 2055ms

arbizu@arbizu:~$
```

Desde el navegador



```
arbizu@arbizu:~$ curl -s -H "Host: staging.megacorp.lab" http://3.88.28.22/
<!doctype html>
<html lang="en"><head><meta charset="utf-8"><title>staging.megacorp.lab</title></head>
<body style="font-family:sans-serif;max-width:720px;margin:3rem auto">
  <h1>Staging</h1>
  <p>Pre-production mirror of the billing app. Directory listing is on.</p>
  <p>Someone dumped a database backup in the web root again.</p>
</body></html>
```

Stagins

```
arbizu@arbizu:~$ curl -s -H "Host: staging.megacorp.lab" http://3.88.28.22/index.html
<!doctype html>
<html lang="en"><head><meta charset="utf-8"><title>staging.megacorp.lab</title></head>
<body style="font-family:sans-serif;max-width:720px;margin:3rem auto">
  <h1>Staging</h1>
  <p>Pre-production mirror of the billing app. Directory listing is on.</p>
  <p>Someone dumped a database backup in the web root again.</p>
</body></html>
arbizu@arbizu:~$ curl -s -H "Host: staging.megacorp.lab" http://3.88.28.22/
<!doctype html>
<html lang="en"><head><meta charset="utf-8"><title>staging.megacorp.lab</title></head>
<body style="font-family:sans-serif;max-width:720px;margin:3rem auto">
  <h1>Staging</h1>
  <p>Pre-production mirror of the billing app. Directory listing is on.</p>
  <p>Someone dumped a database backup in the web root again.</p>
</body></html>
```


(Describe el proceso seguido y, brevemente, el porqué de cada fase. Referencia un estándar si lo usas: p. ej. PTES, OWASP WSTG, OSSTMM.)

1. Reconocimiento y descubrimiento de servicios — <herramientas: nmap...>
2. Enumeración web (vhosts y rutas) — <herramientas: ffuf...>
3. Análisis de vulnerabilidades — <herramientas: nuclei...>

Herramientas utilizadas

Herramienta | Versión | Uso en esta auditoría

NMAP → Reconocimiento y descubrimiento de servicios -nmap

FFUF → Rutas y vhost

Nuclei → para el análisis de vulnerabilidades

```
arbizu@arbizu:~$ nmap --version
Nmap version 7.94SVN ( https://nmap.org )
Platform: x86_64-pc-linux-gnu
Compiled with: liblua-5.4.6 openssl-3.0.13 libssh2-1.11.0 libz-1.3 libpcap-1.10.4
Compiled without:
Available nsock engines: epoll poll select
```

```
arbizu@arbizu:~$ ffuf --version
flag provided but not defined: -version
Fuzz Faster U Fool - v2.1.0-dev
```

```
arbizu@arbizu:~$ nuclei -update-templates

projectdiscovery.io v3.10.0

[INF] nuclei-templates are not installed, installing...
[INF] Your current nuclei-templates are outdated. Latest is v10.4.5
[INF] Successfully updated nuclei-templates (v10.4.5) to /home/arbizu/nuclei-templates. GoodLuck!

Nuclei Templates v10.4.5 Changelog


| TOTAL | ADDED | MODIFIED | REMOVED |
|-------|-------|----------|---------|
| 13651 | 13651 | 0        | 0       |



[INF] No new updates found for nuclei templates
```

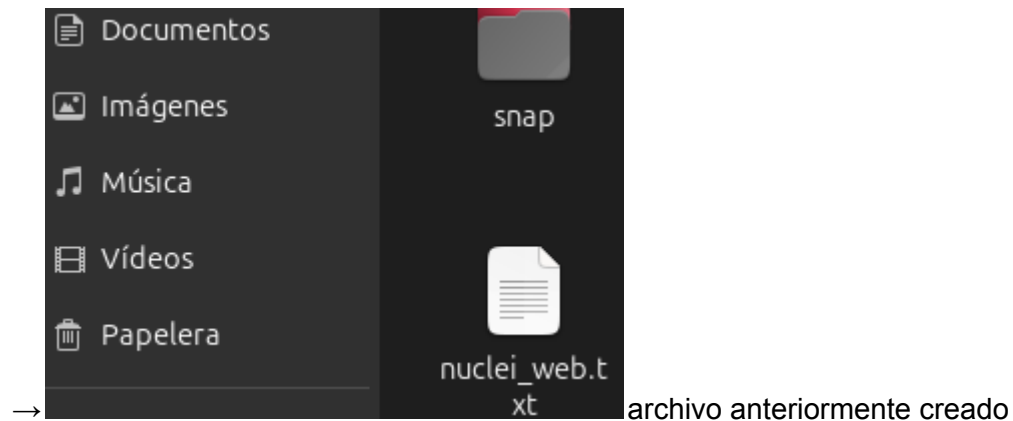
Análisis de las vulnerabilidades

```
arbizu@arbizu:~$ nuclei -u http://3.88.28.22 -o nuclei_web.txt

projectdiscovery.io v3.10.0

[WRN] Found 2 templates with runtime error (use -validate flag for further examination)
[INF] Current nuclei version: v3.10.0 (latest)
[INF] Current nuclei-templates version: v10.4.5 (latest)
```


Resultado de nuclei



FTP (21/tcp)

Anonymous login

Credenciales débiles

vsftpd detectado

FTP expuesto

Redis (6379/tcp)

Versión vulnerable (7.4.9)

Varias CVEs críticas y altas

Redis expuesto sin autenticación

Contraseñas por defecto válidas (iamadmin, admin, root, password, etc.)

Información interna del servidor (used_memory, role:master, etc.)

Campo		Valor
ID		F-03
Severidad		Crítica
CVSS 3.1		9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
Activo afectado		3.88.28.22:6379
Categoría		Exposición de servicio crítico / credenciales por defecto
Estado		Abierto

El servicio Redis versión 7.4.9 está expuesto públicamente sin autenticación y acepta múltiples contraseñas por defecto. Además, nuclei detecta varias vulnerabilidades críticas asociadas a esta versión.

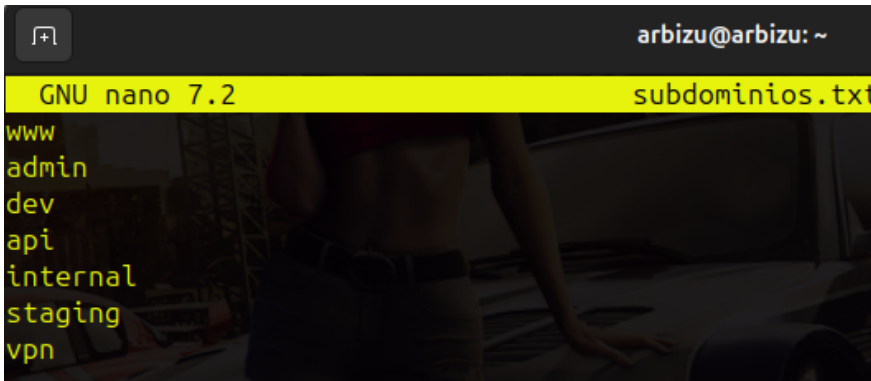
Impacto

Un atacante puede conectarse al servidor Redis, leer o modificar datos internos, ejecutar comandos administrativos y comprometer completamente la aplicación que depende de este servicio.

```
[redis-default-logins] [javascript] [high] 3.88.28.22:6379 [FQDN="3.88.28.22",Host="3.88.28.22",Hostname="3.88.28.22:6379",Port="6379",passwords="lanadmin"]
[redis-default-logins] [javascript] [high] 3.88.28.22:6379 [FQDN="3.88.28.22",Host="3.88.28.22",Hostname="3.88.28.22:6379",Port="6379",passwords="admin"]
[redis-default-logins] [javascript] [high] 3.88.28.22:6379 [FQDN="3.88.28.22",Host="3.88.28.22",Hostname="3.88.28.22:6379",Port="6379",passwords="root"]
[redis-default-logins] [javascript] [high] 3.88.28.22:6379 [FQDN="3.88.28.22",Host="3.88.28.22",Hostname="3.88.28.22:6379",Port="6379",passwords=""]
[redis-default-logins] [javascript] [high] 3.88.28.22:6379 [FQDN="3.88.28.22",Host="3.88.28.22",Hostname="3.88.28.22:6379",Port="6379",passwords="password"]
[redis-info] [javascript] [info] 3.88.28.22:6379 ["used_cpu_user:71.752839","connected_clients:2","connected_slaves:0","used_memory_human:1.14M","role:master","redis_version:7.4.9","process_id:1","used_cpu_sys:12.639985"]
[ftp-anonymous-login] [tcp] [medium] 3.88.28.22:21
[ftp-weak-credentials] [tcp] [high] 3.88.28.22:21 [password="123456",username="ftp"]
[ftp-weak-credentials] [tcp] [high] 3.88.28.22:21 [password="nas",username="ftp"]
[ftp-weak-credentials] [tcp] [high] 3.88.28.22:21 [password="quest",username="ftp"]
[ftp-weak-credentials] [tcp] [high] 3.88.28.22:21 [password="toor",username="ftp"]
[ftp-weak-credentials] [tcp] [high] 3.88.28.22:21 [password="stlgray",username="ftp"]
[ftp-weak-credentials] [tcp] [high] 3.88.28.22:21 [password="pass1",username="ftp"]
[ftp-weak-credentials] [tcp] [high] 3.88.28.22:21 [password="password",username="ftp"]
```

Severidad	Nº
Crítica	2 (Redis, .git expuesto)
Alta	2 (FTP débil, FTP anónimo)
Media	0
Baja	0
Informativa	1 (headers faltantes)
TOTAL	5

Apartado de FFUF



Ejecución de FFUF

```
arbizu@arbizu:~$ ffuf -w subdominios.txt -H "Host: FUZZ.megacorp.lab" -u http://3.88.28.22/ -fs 0 -o ffuf_vhosts.txt
```



v2.1.0-dev

```
:: Method      : GET
:: URL         : http://3.88.28.22/
:: Wordlist    : FUZZ: /home/arbizu/subdominios.txt
:: Header     : Host: FUZZ.megacorp.lab
:: Output file : ffuf_vhosts.txt
:: File format : json
```

—>Esta es la información

```
:: Method      : GET
:: URL         : http://3.88.28.22/
:: Wordlist    : FUZZ: /home/arbizu/subdominios.txt
:: Header     : Host: FUZZ.megacorp.lab
:: Output file : ffuf_vhosts.txt
:: File format : json
:: Follow redirects : false
:: Calibration   : false
:: Timeout      : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 0
```

```
dev          [Status: 200, Size: 344, Words: 30, Lines: 8, Duration: 98ms]
staging      [Status: 200, Size: 349, Words: 30, Lines: 8, Duration: 97ms]
api          [Status: 200, Size: 338, Words: 27, Lines: 9, Duration: 99ms]
vpn          [Status: 200, Size: 488, Words: 56, Lines: 10, Duration: 103ms]
internal     [Status: 200, Size: 643, Words: 80, Lines: 13, Duration: 101ms]
www          [Status: 200, Size: 363, Words: 27, Lines: 11, Duration: 105ms]
:: Progress: [7/7] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Errors: 0 ::
```

Luego la ejecución de FFUF para rutas

```
arbizu@arbizu:~$ ffuf -u http://3.88.28.22/FUZZ \
-H "Host: www.megacorp.lab" \
-w rutas.txt \
-o ffuf_www.txt

      /\_/\  /\_/\  /\_/\
     /  _  \ /  _  \ /  _  \
    /  _  \ /  _  \ /  _  \
   /  _  \ /  _  \ /  _  \
  /  _  \ /  _  \ /  _  \
 /  _  \ /  _  \ /  _  \
/  _  \ /  _  \ /  _  \

v2.1.0-dev

:: Method      : GET
:: URL         : http://3.88.28.22/FUZZ
:: Wordlist     : FUZZ: /home/arbizu/rutas.txt
:: Header      : Host: www.megacorp.lab
:: Output file  : ffuf_www.txt
:: File format  : json
:: Follow redirects: false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

index.html      [Status: 200, Size: 363, Words: 27, Lines: 11, Duration: 100ms]
about.html      [Status: 200, Size: 280, Words: 20, Lines: 7, Duration: 100ms]
:: Progress: [5/5] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Errors: 0 ::
```

```
arbizu@arbizu:~$ ffuf -w subdominios.txt -H "Host: FUZZ.megacorp.lab" -u http://3.88.28.22/ -fs 0 -o
ffuf_vhosts.txt

      /\_/\  /\_/\  /\_/\
     /  _  \ /  _  \ /  _  \
    /  _  \ /  _  \ /  _  \
   /  _  \ /  _  \ /  _  \
  /  _  \ /  _  \ /  _  \
 /  _  \ /  _  \ /  _  \
/  _  \ /  _  \ /  _  \

v2.1.0-dev

:: Method      : GET
:: URL         : http://3.88.28.22/
:: Wordlist     : FUZZ: /home/arbizu/subdominios.txt
:: Header      : Host: FUZZ.megacorp.lab
:: Output file  : ffuf_vhosts.txt
:: File format  : json
:: Follow redirects: false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 0

vpn             [Status: 200, Size: 488, Words: 56, Lines: 10, Duration: 100ms]
www             [Status: 200, Size: 363, Words: 27, Lines: 11, Duration: 102ms]
staging         [Status: 200, Size: 349, Words: 30, Lines: 8, Duration: 98ms]
api            [Status: 200, Size: 338, Words: 27, Lines: 9, Duration: 100ms]
internal        [Status: 200, Size: 643, Words: 80, Lines: 13, Duration: 101ms]
dev            [Status: 200, Size: 344, Words: 30, Lines: 8, Duration: 102ms]
:: Progress: [7/7] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Errors: 0 ::
```

4. SUPERFICIE DE ATAQUE DESCUBIERTA

4.1 Puertos y servicios

Puerto	Proto	Servicio	Versión / banner	Observaciones
21	tcp	FTP	vsftpd 3.0.3	Acceso anónimo permitido; credenciales débiles detectadas; exposición de archivos internos
80	tcp	HTTP (Caddy)	Caddy default	Página por defecto; requiere cabecera Host para acceder a vhosts
443	tcp	HTTPS (Caddy)	Certificado válido	Certificado TLS revela múltiples vhosts internos
8000	tcp	HTTP (nginx)	nginx 1.27.5	Aplicación "Legacy Billing"; repositorio .git expuesto públicamente
8080	tcp	HTTP (Caddy)	Caddy	Servicio "MegaCorp Monitoring"
6379	tcp	Redis	Redis 7.4.9	Servicio expuesto sin autenticación; múltiples CVEs críticas; credenciales por defecto válidas

4.2 Hosts virtuales y rutas relevantes

Host / Ruta	Cómo se descubrió	Notas
www.megacorp.lab	Certificado TLS / curl Host	Sitio principal; contiene navegación y robots.txt
dev.megacorp.lab	Certificado TLS	Entorno de desarrollo (pendiente de análisis)
admin.megacorp.lab	Certificado TLS	Posible panel administrativo (pendiente de acceso)
api.megacorp.lab	Certificado TLS	API interna (pendiente de análisis)
internal.megacorp.lab	Certificado TLS	Entorno interno (pendiente de análisis)
staging.megacorp.lab	Certificado TLS / curl Host	Directory listing activado ; backup de base de datos expuesto
vpn.megacorp.lab	Certificado TLS	Host relacionado con VPN (pendiente de análisis)
/admin	robots.txt	Ruta sensible; posible panel
/backup	robots.txt	Ruta crítica; puede contener ficheros internos
/uploads	robots.txt	Área de subida de archivos
db_backup.sql	staging.megacorp.lab	Backup expuesto en webroot (hallazgo crítico)
dump.tar.gz	staging.megacorp.lab	Archivo comprimido con datos internos

5. HALLAZGOS DETALLADOS

--- Escala de severidad (referencia) -----

Crítica | Compromiso directo: ejecución remota, robo de credenciales, acceso total a datos
Alta | Acceso significativo o exposición de datos sensibles con bajo esfuerzo
Media | Requiere condiciones o encadenamiento; impacto moderado
Baja | Impacto limitado o difícil de explotar
Informativa | Buenas prácticas / visibilidad, sin impacto directo

PLANTILLA DE HALLAZGO (copia este bloque por cada uno)

[F-01] <FTP con acceso anónimo habilitado>

Campo	Valor
ID	F-01
Severidad	Alta
CVSS 3.1	7.5 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)
Activo afectado	3.88.28.22:21
Categoría	Exposición de información / configuración insegura
Estado	Abierto

Descripción

<Qué es la vulnerabilidad y por qué existe.>

El servicio de ftp permite el acceso anónimo sin autenticación por lo tanto no tienes un registro claro de las personas o usuario que pueden acceder de manera que también pone en riesgo la integridad por que no sabes las intenciones que tendrá

Impacto

<Qué consigue un atacante si la explota. Tradúcelo a riesgo de negocio.>

en esta el atacante puede descargar archivos internos, info muy sensible y preparar ataques posteriores contra otros servicios

Evidencia / Prueba de concepto
ftp 3.88.28.22
Name: anonymous
Password: (vacío)

Remediación recomendada
Deshabilitar directory listing.
Mover backups fuera del webroot.
Restringir acceso al entorno de staging.

- <CWE / OWASP / enlace>

6. CADENA DE ATAQUE (NARRATIVA)

<F-0X -> F-0Y -> F-0Z -> impacto final>

Impacto FINAL

El encadenamiento de estos errores posibilita a un atacante:
Tener acceso a datos internos y copias de seguridad
Adquirir el código fuente en su totalidad
Conectarse con Redis y manejar datos esenciales
Hacer que los usuarios y la aplicación se comprometan
Aumentar hasta tener un control total del sistema

En resumen, la cadena de ataque evidencia un compromiso total con la infraestructura, incluyendo el peligro de que se filtren datos, se manipule información y se controle completamente la aplicación.

7. CONCLUSIONES Y RECOMENDACIONES

- Postura de seguridad general:

Es una infraestructura débil y con muchos fallos críticos, se pueden ver configuraciones inseguras, servicios expuestos que no tiene autenticación alguna, credenciales débiles con falta de segmentación. Esto produce un un compromiso del sistema alto con poco esfuerzo a nivel técnico

- Patrones de raíz comunes:

Exposición de ficheros sensibles
(backups en staging, repositorio .git, rutas internas en robots.txt)

Credenciales débiles o inexistentes
(FTP con acceso anónimo, Redis sin autenticación y contraseñas por defecto)

Falta de hardening en servicios críticos
(Redis expuesto, directory listing activado, ausencia de cabeceras de seguridad)

Mala segmentación de entornos
(vhosts internos accesibles desde Internet)

Errores de despliegue

(código fuente publicado con .git, backups en webroot)

- Plan de remediación priorizado:

Prioridad | Acción | Hallazgos que mitiga | Esfuerzo

Prioridad	Acción	Hallazgos que mitiga	Esfuerzo
1	terminar exposicion de Redis(firewall y autenticaciones)	F-03	Medio
2	Eliminar git del servidor web y revisa repos secretos	F-04	Bajo
3	Desactiva directory listing y retirar backups de webroot	F-05	Bajo
4	deshabilitar acceso anónimo FTP	F-01, F-02	Bajo
5	Restringir VHOST internos (los cuales son "dev, admin,internal, api,VPN) mediante el firewall	F-06 (indirecto)	Medio
6	Implementar cabeceras de seguridad en caddy/nginx	Informativos	Bajo
7	Revisar robots.txt para evitar exposición de rutas sensibles	F-06	Bajo

8. ANEXOS

A. Wordlists o scripts propios utilizados

```

arbizu@arbizu:~$ ffuf -w subdominios.txt -H "Host: FUZZ.megacorp.lab" -u http://3.88.28.22/ -fs 0 -c
ffuf_vhosts.txt

      /\_/\  /\_/\  /\_/\
     /\_/\  /\_/\  /\_/\
    /\_/\  /\_/\  /\_/\  /\_/\  /\_/\  /\_/\  /\_/\
   /\_/\  /\_/\  /\_/\  /\_/\  /\_/\  /\_/\  /\_/\
  /\_/\  /\_/\  /\_/\  /\_/\  /\_/\  /\_/\  /\_/\
 /\_/\  /\_/\  /\_/\  /\_/\  /\_/\  /\_/\  /\_/\
/_/\_/\  /\_/\  /\_/\  /\_/\  /\_/\  /\_/\  /\_/\

v2.1.0-dev

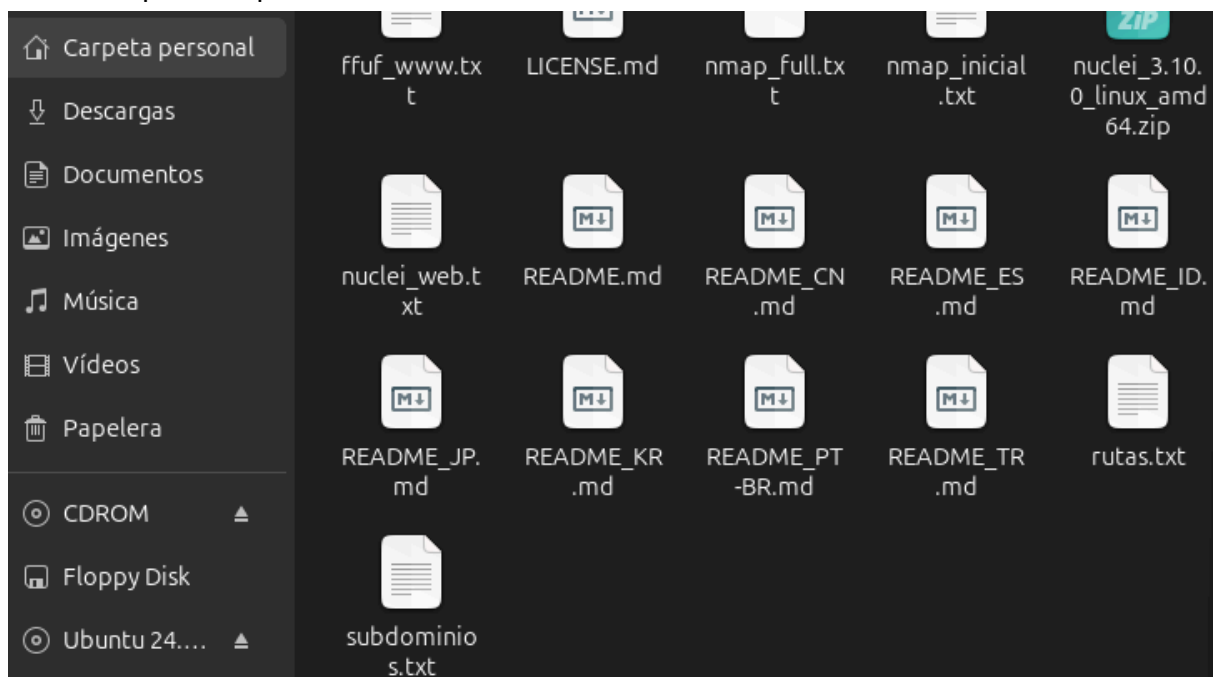
arbizu@arbizu:~$ ffuf -u http://3.88.28.22/FUZZ -H "Host: www.megacorp.lab" -w rutas.txt -o ffuf_ww
.txt~
admin
backup
uploads
about.html
index.html

Ubicación:

v2.1.0-dev

```

En esta captura se pueden ver los archivos creados



```
arbizu@arbizu:~$ cat subdominios.txt
www
admin
dev
api
internal
staging
vpn
arbizu@arbizu:~$ cat rutas.txt
admin
backup
uploads
about.html
index.html
```

la información que contiene